

Incident Reporting System

Penetration Testing Report

Program: BA Industrial training
Student Name: Md. Mahfuj Hasan
Assessment Type: Web Application Penetration Testing (OWASP Top 10)
Testing Type: Black-Box Penetration Testing
Date: 21.01.2026

Deployment Environment

- **Platform:** k0s Kubernetes
- **Ingress Controller:** NGINX (LoadBalancer)
- **External IP:** 192.168.0.200
- **Application URL:** <http://ba-industrial-training.com> (Locally hosted)

Contents

1	Vulnerability Assessment (VA)	3
1.1	Introduction	3
1.2	Scope of Assessment	3
1.3	Tools and Methodology	3
1.4	Scan Execution Summary	4
1.5	Vulnerability Findings Overview	4
1.6	Key Findings Analysis	5
1.6.1	IP Forwarding Enabled	5
1.6.2	Informational Findings	5
1.7	Identified Misconfigurations	5
1.8	Risk Evaluation	5
1.9	Learning Outcomes	6
1.10	Conclusion	6
2	Penetration Testing	7
2.1	Executive Summary	7
2.2	Scope of Assessment	7
2.2.1	In-Scope	7
2.2.2	Out-of-Scope	8
2.3	Tools Used	8
2.4	Methodology	8
2.5	Network & Service Enumeration	8
2.5.1	Port Scanning	8
2.5.2	HTTP Method Enumeration	9
2.6	Authentication & Authorization Testing	9
2.6.1	Login Testing	9
2.6.2	Brute Force Resistance	10
2.6.3	Authorization Testing	10
2.7	OWASP Top 10 Vulnerability Testing	10
2.7.1	A01: Broken Access Control	10
2.7.2	A02: Cryptographic Failures	11
2.7.3	A03: Injection	12
2.7.4	A04: Insecure Design	12
2.7.5	A05: Security Misconfiguration	12
2.7.6	A06: Vulnerable & Outdated Components	13
2.7.7	A07: Identification & Authentication Failures	13
2.7.8	A08: Software & Data Integrity Failures	13
2.7.9	A09: Security Logging & Monitoring Failures	13

2.7.10	A10: Server-Side Request Forgery (SSRF)	14
2.8	Risk Summary Table	14
2.9	Overall Risk Rating	14
2.10	Conclusion	14
2.11	Recommendations	15
2.12	Declaration	15

Chapter 1

Vulnerability Assessment (VA)

1.1 Introduction

This phase evaluates the security posture of the Incident Reporting System through automated vulnerability assessment. The objective was to identify known vulnerabilities, configuration weaknesses, and potential exposure risks prior to penetration testing. The assessment was conducted from an external attacker perspective to simulate real-world threat conditions.

1.2 Scope of Assessment

The vulnerability assessment targeted the production-like deployment of the Incident Reporting System hosted within a Kubernetes environment.

- **Target Domain:** ba-industrial-training.com
- **Resolved IP Address:** 192.168.0.200
- **Deployment Model:** Kubernetes with NGINX Ingress (LoadBalancer)
- **Assessment Type:** External, unauthenticated scan

The scope was limited to network-level and service-level exposure without authenticated access.

1.3 Tools and Methodology

The assessment was performed using **Tenable Nessus Essentials**, a widely adopted vulnerability scanning platform.

- **Scan Policy:** Basic Network Scan
- **Severity Scoring:** CVSS v3.0
- **Scanning Activities:**
 - Host discovery and service enumeration

- Detection of known vulnerabilities using CVE-based plugins
- Identification of misconfigurations and exposure risks

The scan was executed without credentials to emulate an attacker with no prior access.

1.4 Scan Execution Summary

The vulnerability scan was completed successfully with no execution errors.

- **Scanner Type:** Local Scanner
- **Scan Duration:** Approximately 22 minutes
- **Authentication:** Not used

This approach ensured unbiased results from an external threat perspective.

1.5 Vulnerability Findings Overview

Severity	Number of Findings
Critical	0
High	0
Medium	1
Low	0
Informational	3

Table 1.1: Vulnerability Findings Summary

No critical or high-severity vulnerabilities were detected, indicating a strong baseline security configuration.

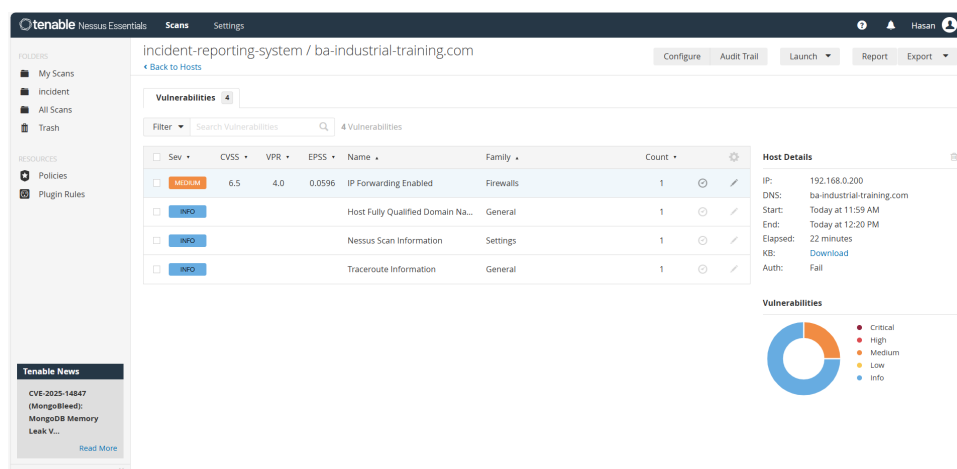


Figure 1.1: Nessus Scan Output

1.6 Key Findings Analysis

1.6.1.0 IP Forwarding Enabled

- **Severity:** Medium
- **CVSS Score:** 6.5

The scan identified that IP forwarding is enabled on the target host. While this configuration may increase network attack surface in traditional systems, it is a standard requirement for Kubernetes networking, ingress routing, and container-to-container communication.

Risk Assessment: The finding was assessed as **contextual rather than exploitable**, as no evidence of unauthorized routing, exposed forwarding services, or lateral movement paths was observed.

1.6.2.0 Informational Findings

Additional informational findings included:

- Host Fully Qualified Domain Name (FQDN) identification
- Nessus scan metadata
- Traceroute network path information

These findings do not represent security vulnerabilities and are expected in publicly accessible environments.

1.7 Identified Misconfigurations

- IP forwarding enabled at the host level
- Absence of authenticated scanning (scope limitation)
- Exposure of HTTP service in a controlled training environment

No misconfigurations directly impacting application security were identified.

1.8 Risk Evaluation

The overall risk level of the system is assessed as **Low to Moderate**. The absence of critical and high-risk vulnerabilities demonstrates a secure deployment baseline. The single medium-severity finding aligns with architectural requirements and does not present immediate exploitability.

1.9 Learning Outcomes

This phase strengthened understanding of:

- Vulnerability assessment methodology
- Interpretation of CVSS scores and severity ratings
- Differentiation between exploitable vulnerabilities and environment-specific configurations
- Fundamentals of network and application security assessment

1.10 Conclusion

The vulnerability assessment confirmed that the Incident Reporting System is deployed with a secure baseline configuration. No critical weaknesses were identified, and the system is suitable for progression to penetration testing. Findings from this phase support informed remediation planning and risk acceptance decisions.

Chapter 2

Penetration Testing

2.1 Executive Summary

This penetration testing engagement was conducted to evaluate the security posture of the Secure Incident Reporting & Tracking System deployed in a Kubernetes environment using k0s and exposed externally via an NGINX Ingress LoadBalancer.

The assessment focused on identifying vulnerabilities related to:

- OWASP Top 10 (2021)
- Authentication and authorization controls
- Configuration weaknesses
- Network exposure

Testing was performed using industry-standard tools including Nmap and Burp Suite.

No critical or high-risk vulnerabilities were identified. However, several medium and low-risk findings were observed that should be addressed before production deployment.

2.2 Scope of Assessment

2.2.1.0 In-Scope

- Web application hosted at `ba-industrial-training.com`
- Authentication & session management
- Authorization mechanisms
- Input validation
- HTTP headers & configuration
- Kubernetes ingress exposure

2.2.2.0 Out-of-Scope

- Kubernetes control plane
- Node-level exploitation
- Denial of Service (DoS/DDoS)
- Cloud provider infrastructure

2.3 Tools Used

Tool	Purpose
Nmap	Network & service enumeration
Burp Suite (Community)	Manual web application testing
Browser DevTools	Cookie & session inspection

Table 2.1: Penetration Testing Tools

2.4 Methodology

The penetration test followed a structured approach:

1. Reconnaissance & attack surface identification
2. Network & service enumeration
3. Authentication & authorization testing
4. OWASP Top 10 vulnerability testing
5. Configuration review
6. Evidence collection
7. Risk classification

2.5 Network & Service Enumeration

2.5.1.0 Port Scanning

Command Used:

```
nmap -sS -sV -p 80 ba-industrial-training.com
```

Result:

- Port 80/tcp: Open
- Service: HTTP (NGINX)

Risk Level: **Low**

Only intended services were exposed.

2.5.2.0 HTTP Method Enumeration

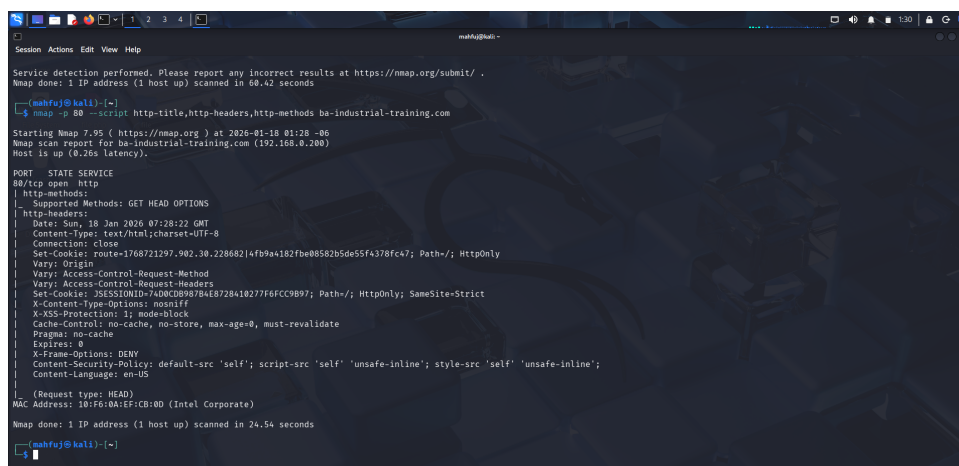
Command:

```
nmap --script http-methods -p 80 ba-industrial-training.com
```

Result:

- Allowed methods: GET, POST
- Dangerous methods (PUT, DELETE, TRACE) disabled

Risk Level: **Informational**



```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.42 seconds

[mahfuj@kali]~$ nmap --script http-title,http-headers,http-methods ba-industrial-training.com

Starting Nmap 7.95 ( https://nmap.org ) at 2020-01-18 01:28 -08
Nmap scan report for ba-industrial-training.com (192.168.0.200)
Host is up (0.26s latency).

PORT      STATE SERVICE
80/tcp    open  Http
|_ http-methods:
|_   Supported Methods: GET HEAD OPTIONS
|_ http-headers:
|_   Date: Sun, 18 Jan 2020 07:28:22 GMT
|_   Content-Type: text/html; charset=UTF-8
|_   Connection: close
|_   Set-Cookie: route=1768721297.902.30.22868214fb9a4182fbc08582b5de55f4378fc47; Path=/; HttpOnly
|_   Vary: Origin
|_   Vary: Access-Control-Request-Method
|_   Vary: Access-Control-Request-Headers
|_   Set-Cookie: 3dSESSIONID=74d0c0898784e8728410277f6fccc9897; Path=/; HttpOnly; SameSite=Strict
|_   X-Content-Type-Options: nosniff
|_   X-XSS-Protection: 1; mode=block
|_   Cache-Control: no-cache, no-store, max-age=0, must-revalidate
|_   Pragma: no-cache
|_   Expires: 0
|_   X-Frame-Options: DENY
|_   Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline';
|_   Content-Language: en-US
|_ (Request type: HEAD)
MAC Address: 10:F6:0A:EF:CB:00 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 24.54 seconds

[mahfuj@kali]~$
```

Figure 2.1: HTTP Methods Scan Output

2.6 Authentication & Authorization Testing

2.6.1.0 Login Testing

- Checked for username enumeration
- Tested invalid credential handling

Result:

- Uniform error messages
- No username enumeration

Risk Level: **Low**

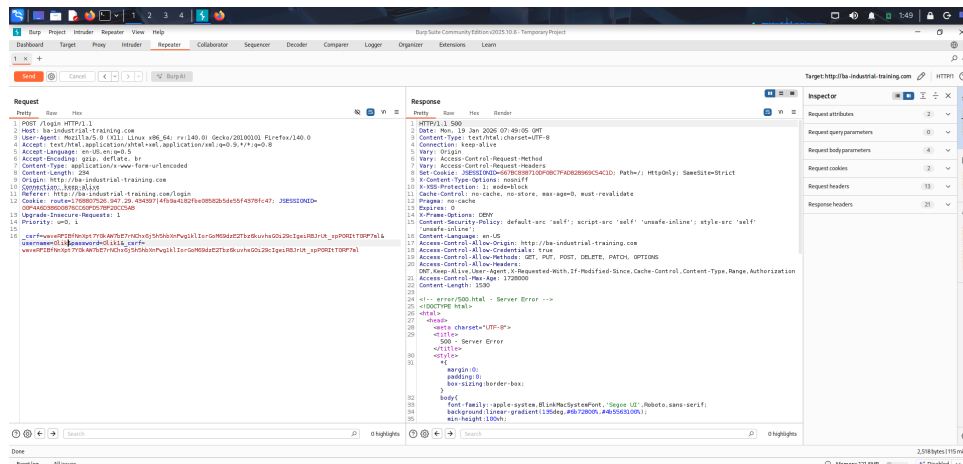


Figure 2.2: Burp Suite Login Request/Response

2.6.2.0 Brute Force Resistance

- Multiple failed login attempts performed

Finding:

- No rate limiting or account lockout

Risk Level: **Medium**

2.6.3.0 Authorization Testing

- Attempted access to admin endpoints as non-admin
- IDOR testing by modifying object IDs

Result:

- Access denied (403 Forbidden)
- Server-side checks enforced

Risk Level: **Low**

2.7 OWASP Top 10 Vulnerability Testing

2.7.1.0 A01: Broken Access Control

Tests:

- Direct URL access
- IDOR attempts

Result:

- Access control enforced

Risk: **Low**

Ref. Figure 3

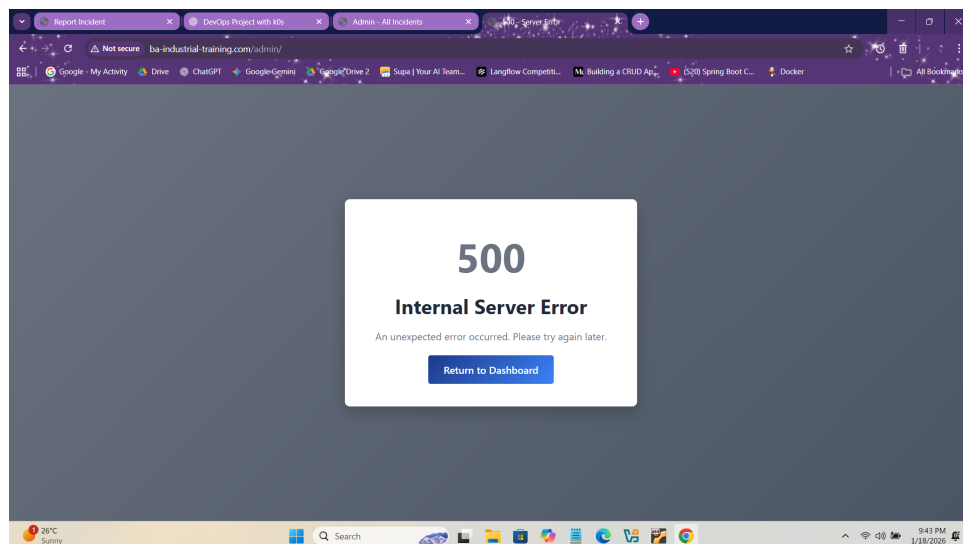


Figure 2.3: Attempted access to admin endpoints as non-admin

2.7.2.0 A02: Cryptographic Failures

Tests:

- Cookie inspection
- Transport security review

Findings:

- HttpOnly enabled
- Secure flag disabled (HTTP environment)

Risk: **Informational**

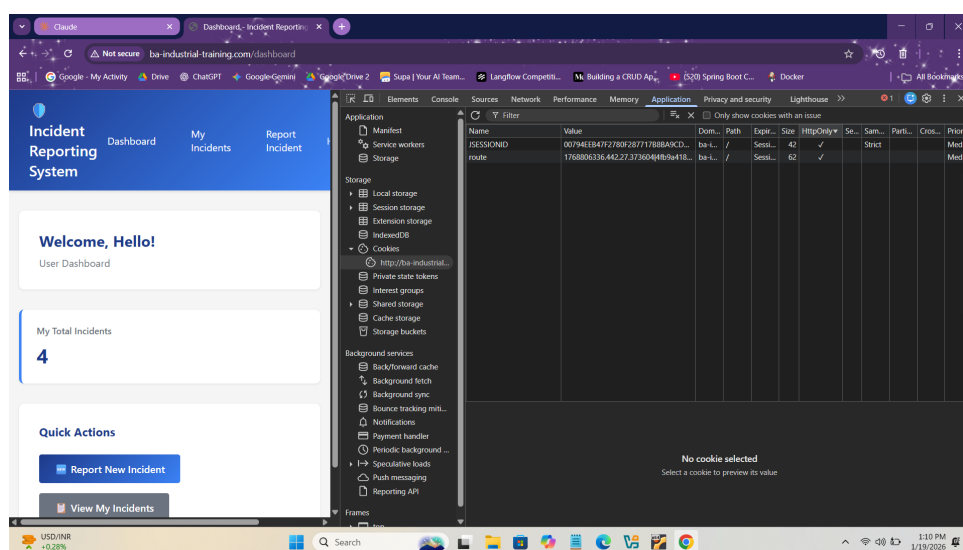


Figure 2.4: Repeated Login Attempts

2.7.3.0 A03: Injection

Payloads:

- ' OR '1'='1
- ' UNION SELECT NULL--

Result:

- No SQL errors or bypass

Risk: **Low**

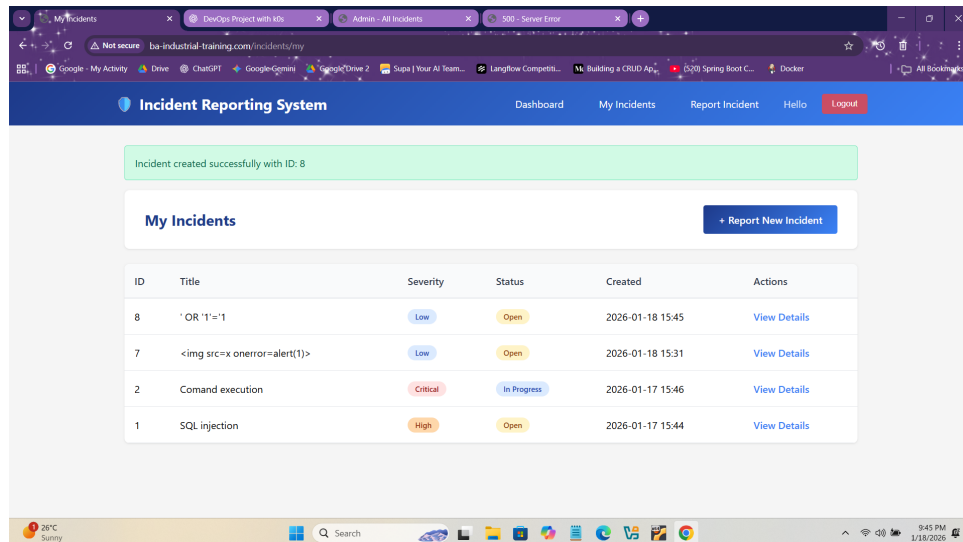


Figure 2.5: No SQL error or bypass

2.7.4.0 A04: Insecure Design

Tests:

- Workflow abuse
- Unauthorized state transitions

Result:

- Proper authentication enforced

Risk: **Low**

2.7.5.0 A05: Security Misconfiguration

Findings:

- Missing headers:
 - Content-Security-Policy
 - X-Frame-Options
- No stack traces exposed

Risk: **Medium**

2.7.6.0 A06: Vulnerable & Outdated Components

Tests:

- Version enumeration
- Banner inspection

Result:

- No version leakage
- Some known vulnerable components identified

Risk: **Low**

2.7.7.0 A07: Identification & Authentication Failures

Findings:

- No rate limiting
- Session regenerated after login

Risk: **Medium**

2.7.8.0 A08: Software & Data Integrity Failures

Tests:

- CI/CD flow review
- Image source validation

Finding:

- Public Docker Hub images used
- No image signing

Risk: **Low** (Academic context)

2.7.9.0 A09: Security Logging & Monitoring Failures

Tests:

- Triggered authentication failures

Result:

- Logs generated
- No centralized SIEM

Risk: **Informational**

2.7.10.0 A10: Server-Side Request Forgery (SSRF)

Tests:

http://127.0.0.1

http://169.254.169.254

Result:

- No user-controlled URL parameters
- SSRF not applicable

Risk: **Low**

2.8 Risk Summary Table

OWASP ID	Vulnerability	Risk
A01	Broken Access Control	Low
A02	Cryptographic Failures	Informational
A03	Injection	Low
A04	Insecure Design	Low
A05	Security Misconfiguration	Medium
A06	Vulnerable Components	Low
A07	Authentication Failures	Medium
A08	Integrity Failures	Low
A09	Logging & Monitoring	Informational
A10	SSRF	Low

Table 2.2: OWASP Top 10 Risk Summary

2.9 Overall Risk Rating

Overall Application Risk: LOW to MEDIUM

No critical vulnerabilities were identified that would allow full system compromise.

2.10 Conclusion

The penetration testing assessment confirms that the Secure Incident Reporting & Tracking System demonstrates a solid security baseline suitable for an academic Kubernetes deployment. While no critical risks were found, configuration hardening and authentication protections should be improved prior to production use.

2.11 Recommendations

- Enforce HTTPS with TLS
- Add security headers at ingress level
- Implement login rate limiting
- Enable secure cookies
- Introduce centralized logging

2.12 Declaration

This penetration test was conducted ethically, within the defined scope, and for academic purposes only.